

SGMA APP — Final Readiness Report

Document type: Readiness audit, verification & reporting (no code/schema/route/permission changes)
Date: 2026-06-06 **Version:** Stable Beta **Prepared for:** SGMA Board / external beta testers

1. Executive Summary

SGMA APP is a mobile-first, bilingual (Arabic-primary, RTL) member community web application for the Syrian-German Medical Association. It provides membership management, news, member-authored articles with moderation, public and member↔administration chat, official broadcast announcements, a Board of Directors directory, volunteer medical delegation registration with PDF attachments, and a role-based admin dashboard. Authentication is JWT-based (no Firebase), and all role/permission rules are enforced on the backend (the server is the source of truth; the UI only hides what the user cannot do).

A full readiness audit was performed against the live running application. All 16 audited areas function as designed. No blocking defects were found. The application is assessed as **Stable Beta — ready for external board testing**, with a short pre-publish checklist (mostly operational hardening such as rotating the super-admin test password and clearing demo data) recommended before a wide public launch.

2. Current Status

Item	Status
Backend API server	Running, healthy (public endpoints 200, protected endpoints correctly gated 401/403)
Frontend web app	Running, loads cleanly (/ , /login , /register , /more all 200)
Database	PostgreSQL + Drizzle, 14 tables, reachable
Authentication	JWT, working; pending/inactive users correctly blocked
Typecheck	Full workspace typecheck passes
Backup	Code zip + gzipped SQL dump produced (point-in-time)

3. Completed Modules

- Authentication & Account Approval** — register (with required membership number), admin approval flow, login with role match, blocked pending/suspended/inactive accounts.
- User Profile (My Account)** — view/edit profile, avatar upload, password change, read-only membership number.
- Role System** — MEMBER, MODERATOR, ADMIN, SUPER_ADMIN.
- Admin Dashboard** — users, articles, news, broadcasts, internal announcements/ads management (SUPER_ADMIN only), with role-scoped visibility.
- News** — list, detail, image support, staff-managed publishing.
- Articles** — list, detail, write, my articles, PENDING→APPROVED moderation workflow, image support.

7. **Chat** — public members room + member↔administration direct chat; edit/delete rules; polling-based; mobile layout.
8. **Broadcasts** — create (role-protected), global top banner, read-only for members.
9. **Board of Directors** — landing + current board cards; create/edit/soft-delete for ADMIN/SUPER_ADMIN; image upload.
10. **Volunteer Delegations** — member registration form, PDF upload, save/print as PDF, my requests, staff review page.
11. **Static / Information Pages** — About SGMA, Privacy Policy, Terms, Developer Info (developer-only edit where applicable).
12. **More page** — organized, role-based navigation.

4. Role / Permission Matrix

Backend-enforced. UI gating is convenience only.

Capability	MEMBER	MODERATOR	ADMIN	SUPER_ADMIN
Read news / articles / board / chat	✓	✓	✓	✓
Write article (→ pending review)	✓	✓	✓	✓
Submit volunteer delegation (ACTIVE only)	✓	✓	✓	✓
Approve/reject articles, manage news	—	✓	✓	✓
Review volunteer delegation requests	—	✓	✓	✓
Manage users / activate pending accounts	—	—	✓	✓
Manage broadcasts	—	—	✓	✓
Manage Board of Directors	—	—	✓	✓
Assign roles	—	—	up to MODERATOR	all
Act on SUPER_ADMIN targets	—	—	—	✓
Internal announcements/ads management	—	—	—	✓

Safety rules verified: cannot change your own role; cannot deactivate/suspend yourself; cannot demote or deactivate the last login-eligible super admin; ADMIN cannot act on SUPER_ADMIN targets or assign ADMIN/SUPER_ADMIN.

5. Tested Flows

- **Auth gates:** unauthenticated requests to protected endpoints → 401; non-privileged roles to management endpoints → 403; valid login returns token + user. ✓
- **Account approval:** new signups created as PENDING with no token; login blocked until an admin activates. ✓
- **Role enforcement (live curl):** SUPER_ADMIN management actions succeed; ADMIN/MODERATOR/MEMBER blocked (403) on restricted endpoints; any authenticated user can read permitted content. ✓

- **Input validation:** required-field/email/date-range/image-type-and-size/PDF-type-and-size checks return proper 400s; malformed IDs → 400; missing records → 404. ✓
- **Frontend pages:** all 22 audited pages render correctly at mobile viewport (402×874), authenticated where required, RTL layout intact, bottom navigation present, no horizontal scrolling observed. ✓
- **Health:** public API endpoint 200; frontend root/login/register/more 200. ✓

6. Known Issues / Limitations

- **No self-service password reset.** Members who forget their password must contact an administrator. (Documented in the user guide troubleshooting section.)
- **Chat is polling-based (7-10s refresh), not real-time WebSockets.** Acceptable for current scale; messages may take a few seconds to appear.
- **Images and PDFs are stored as base64 in the database** (no external object storage yet). Functional, but increases row size and request payloads; consider object storage before large-scale growth.
- **Demo/sample data is present** (sample news, articles, board members, and test accounts). Should be cleared or clearly marked before public launch.
- **Board "Previous" and "History" sub-pages are placeholders.** "Current board" is fully functional.
- **PDF/DOCX of this documentation** were generated in-environment via headless Chromium; final formatting may be refined in Word if desired.

None of the above are blocking for board-level beta testing.

7. Recommended Pre-Publish Checklist

- ☐ Change SUPER_ADMIN password from the test value.
 - ☐ Remove or disable test accounts (test member/admin/moderator).
 - ☐ Remove demo/sample data or clearly mark it as sample.
 - ☐ Verify the published external link loads cleanly.
 - ☐ Republish the latest version.
 - ☐ Test on Android (Chrome).
 - ☐ Test on iPhone / Safari.
 - ☐ Confirm About / Privacy / Terms pages content is final.
 - ☐ Confirm membership approval flow end-to-end with a real new signup.
 - ☐ Confirm admin role assignments are correct for real staff.
 - ☐ Back up code / create a named checkpoint.
 - ☐ Back up / export the database.
 - ☐ Collect beta feedback from board testers.
-

8. Risk Assessment

Risk	Likelihood	Impact	Mitigation
Test super-admin credentials left unchanged	Medium	High	Rotate password before publish (checklist)

Risk	Likelihood	Impact	Mitigation
Demo data confuses real users	Medium	Low	Clear/mark sample data before publish
Base64 media bloats DB at scale	Low (now)	Medium	Migrate to object storage in a later phase
No password reset increases admin support load	Medium	Low	Document contact path; add reset in a later phase
Polling chat under heavy load	Low	Low	Move to WebSockets if usage grows

Security posture: no Firebase, no MySQL migration, no secrets in code or backups, role-based access enforced server-side, pending users blocked, only active users can log in, last-super-admin protections in place.

9. Final Readiness Score

Stable Beta — ready for external board testing.

No major blockers. The application is functionally complete across all audited modules and enforces its permission model on the backend. Complete the pre-publish checklist (primarily credential rotation and demo-data cleanup) before a wide public release.